

# Responding to a Nation-State Cyber Attack



*[Your Name]*  
*[Date]*

# How to Use this Template

- We have provided these slides as a guide to ensure you submit all the required components to complete your project successfully.
- When presenting your project, remember that these slides are merely a guide. We strongly encourage you to embrace your creative freedom and make changes that reflect your unique vision as long as the required information is present.
- You can add slides to the template when your answers or screenshots do not fit on the previously provided pages.
- Delete this and the next slide before submitting your project.
- **Remember to add your name and the date to the cover page.**



# Project Scenario

---

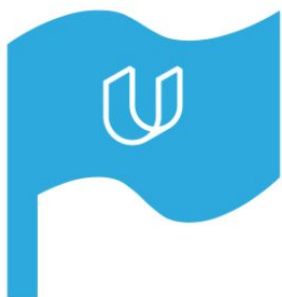
# What Are We Doing?

**South Udan** is a small island nation that is a peaceful and technologically advanced nation! Because of its small size, the country believes in efficiently using its land and natural resources. Their scientists recently came up with a novel and cleaner means of performing nuclear fission of an element called Tridanium. This allows them to generate 100 times more energy and drastically reduce nuclear waste, thus making it the most efficient and clean way to generate electricity. This enabled them to generate cleaner and cheaper electricity, thus improving the lives of their citizens.

**North Udan** was extremely jealous of the progress of their neighbors. They still rely on using coal and other fossil fuels which are known to speed up global warming. In order to disrupt South Udan program, the government of North Udan decides to launch a cyberattack on South Udan Tridanium processing plant and disrupt its operation.

# What Are We Doing?

**The National Peace Agency of North Udan**, which is an undercover organization that runs the nation-state espionage program, launches an attack during a national holiday in South Udan (the holiday marks 50 years of border separation of the two nations). They manage to compromise a linux server which serves as a jump host to connect the Tridanium processing plant to the internet. They attempted to brute force the password of an employee account which triggered a security alarm. You have been immediately called onboard to respond to the security alarm and contain the ongoing cyberattack. You will begin the investigation from the compromised jump box to detect and mitigate the threats. Since it's a mission-critical server, you are also tasked with immediately hardening the server to proactively defeat future attacks from North Udan.





# Section One: Detection

---



# ClamAV Scan

As a first threat detection measure, you will have to perform an antivirus scan on the system to determine the malware files planted by the National Peace Agency on the processing plant's server. Launch ClamAV malware scanner and perform a scan on the 'Downloads' directory (/home/ubuntu/Downloads/). Paste the scan results below:

```
ubuntu@ubuntu-VirtualBox:~$ clamscan -r ~/Downloads
LibClamAV Warning:
*****
LibClamAV Warning: *** The virus database is older than 7 days! ***
LibClamAV Warning: *** Please update it as soon as possible. ***
LibClamAV Warning:
*****
/home/ubuntu/Downloads/moni.lod: OK
/home/ubuntu/Downloads/notes.txt: OK
/home/ubuntu/Downloads/SSH-One: OK
/home/ubuntu/Downloads/gates.lod: OK
/home/ubuntu/Downloads/ft32: Unix.Malware.Agent-6774375-0
FOUND
/home/ubuntu/Downloads/ft64: Unix.Malware.Agent-6774336-0
FOUND
/home/ubuntu/Downloads/wipefs: Unix.Tool.Miner-6443173-0 FOUND
/home/ubuntu/Downloads/tmplog: OK

----- SCAN SUMMARY -----
Known viruses: 8874078
Engine version: 0.100.3
```



# Suspicious File Identification

You know that the National Peace Agency has an advanced infiltration group. As a curious investigator, you still want to explore other files available in the Downloads folder, despite the ClamAV scan detecting some files as malware. Can you spot one more suspicious file which should have been a cause of infection but managed to defeat your ClamAV scan? Find this filename and the embedded callout URLs hardcoded in this file. This callout domain is the Command & control server of the National Peace agency.

|                       |                                                                                        |
|-----------------------|----------------------------------------------------------------------------------------|
| Suspicious file name: | <i>[SSH-One]</i>                                                                       |
| Callout URLs:         | <i>[<br/>http://darkl0rd.com:7758/SSH-T<br/>http://darkl0rd.com:7758/SSH-One<br/>]</i> |





# Yara Rule Creation

Once you have ensured the presence of a unique malware file that could not be detected through ClamAV scan, you also want to ensure that there is a signature or rule in place so that you can scan your other servers for the presence of the same file. Create a Yara rule file that can be compiled with ClamAV to detect the unique malware you have identified in the task above. Paste the Yara rule below:

```
rule NPA_Darkl0rd_SSH_Downloader
{
  meta:
    description = "Detects NPA-style bash downloader that fetches SSH-T and SSH-One from darkl0rd C2"
    author = "Samuel Hailemariam"
    reference = "Local malware investigation"
    date = "2026-06-23"
    malware_family = "NPA_Darkl0rd_Downloader"
    severity = "high"

  strings:
    $shebang = "#!/bin/bash" ascii

    $url1 = "http://darkl0rd.com:7758/SSH-T" ascii
    $url2 = "http://darkl0rd.com:7758/SSH-One" ascii
    $domain = "darkl0rd.com:7758" ascii

    $payload1 = "m=SSH-T" ascii
    $payload2 = "script=SSH-One" ascii
```



# Section Two: Mitigation

---



# Implement HIDS

The first security alarm about the ongoing cyberattack came from the Host-Based Intrusion Detection System is about multiple failed login attempts from a foreign IP address. Launch the host IDS and analyze the logs and events captured in the system. To verify that the IDS is up and working, try connecting to the virtual machine via SSH and notice the new login entry created in the IDS web UI. Take a snapshot of the newly created log lines and paste it below.

The screenshot shows the OSSEC Web Interface running in a Mozilla Firefox browser within an Oracle VM VirtualBox window. The browser address bar shows `localhost/ossec/index.php`. The interface displays the OSSEC logo (Version 0.8) and navigation tabs: Main, Search, Integrity checking, Stats, and About. The main content area is divided into three sections:

- Available agents:** Lists `+ossec-server (127.0.0.1)`.
- Latest modified files:** Lists `+etc/resolv.conf`, `+etc/subgid`, `+etc/group`, `+etc/gshadow`, and `+etc/gshadow`.
- Latest events:** Displays a list of security events with details such as Level, Rule Id, Location, and Src IP.

The latest events section shows three entries:

- Level: 3 - Login session closed.** Rule Id: 5502. Location: `ubuntu-VirtualBox->/var/log/auth.log`. Timestamp: 2026 Jun 23 07:03:40. Log message: `Jun 23 07:03:39 ubuntu-VirtualBox sshd[7104]: pam_unix(sshd:session): session closed for user ubuntu`.
- Level: 3 - Login session opened.** Rule Id: 5501. Location: `ubuntu-VirtualBox->/var/log/auth.log`. Timestamp: 2026 Jun 23 07:03:28. Log message: `Jun 23 07:03:27 ubuntu-VirtualBox sshd[7104]: pam_unix(sshd:session): session opened for user ubuntu by (uid=0)`.
- Level: 3 - SSHD authentication success.** Rule Id: 5715. Location: `ubuntu-VirtualBox->/var/log/auth.log`. Src IP: 192.168.56.1. User: ubuntu. Timestamp: 2026 Jun 23 07:03:28. Log message: `Jun 23 07:03:27 ubuntu-VirtualBox sshd[7104]: Accepted password for ubuntu from 192.168.56.1 port 56987 ssh2`.

The bottom of the screen shows the Ubuntu desktop environment with various application icons and a system tray displaying the date and time as 15:08 on 23/06/2026.



## Locate Suspicious IP

Once you have verified that the IDS is working fine, you are now required to collect the next indicator of compromise (IoC), which is the IP address that attempted to break into the system. This IoC will prove significant in attributing the threat actors behind the cyber attack. You were told that the initial security alarm consisted of multiple failed login attempts on the jump host server. To verify that, filter the IDS alerts to specifically look for failed logins followed by a successful one. To further disrupt the network after a successful login, the attackers execute a command to elevate their privilege to system root. Your goal is to identify that IP address which made the login attempts and then performed privilege escalation to the 'root' user. Since the attack happened in 2020, you should search in that year.

|                           |                       |
|---------------------------|-----------------------|
| <b>The attacker's IP:</b> | <i>[192.168.56.1]</i> |
|---------------------------|-----------------------|



## IPtables Rule

Once you have identified the attacking IP address, you are now required to create an IPtables rule to make sure that any SSH connection requests from this host are blocked in the future. Hopefully, this will stop this agent from the so-called National Peace Agency from connecting again. Report your IP table rule below that will deny SSH access to the attacking IP.

|                       |                                                                                   |
|-----------------------|-----------------------------------------------------------------------------------|
| <b>IPtables rule:</b> | <code>[sudo iptables -I INPUT 1 -p tcp -s 192.168.56.1 --dport 22 -j DROP]</code> |
|-----------------------|-----------------------------------------------------------------------------------|



# Detect Username, Process & Port

Once the attackers managed to break into the system, they created a backdoor username and launched a process that allows them to log in through a non-standard port number. This is a common tactic implemented by nation-state actors to ensure continuous access to the compromised system. Your goal is:

- **Identify the rogue username:** Analyze the logs to find the rogue user added to the system. Once you have the username, you'd want to view the `/var/log/auth.log` to check for the authorization events. Next, fetch all processes that are currently running for that user.
- **Locate the malicious process:** Consider that the newly created rogue user has sufficient permissions to use the root credentials to run the backdoor process. Therefore, you will not find a process running in the name of the rogue user. Instead, ***the backdoor process will be running as root***. Analyze the currently running processes to find that suspicious process.
- **IP address/port:** Once you have the process name with you, find the "non-standard" port it is listening on.

|                        |                      |
|------------------------|----------------------|
| Backdoor user:         | <i>[darklord]</i>    |
| Backdoor process name: | <i>remotesec</i>     |
| Backdoor process port: | <i>0.0.0.0:56565</i> |



# Disable SSH Root Access

So far, we have figured out that the attack was carried out through brute-forcing ssh login credentials. Can you update the SSH configuration file to ensure that root login through SSH is never allowed, even if the correct set of credentials have been used? Report your changes by modifying the respective configuration entry and providing a snapshot of the change you have made. Create a screenshot of the change, and paste it below.

```
analysis_image_final [Running] - Oracle VirtualBox
Machine View Input Devices Help

ubuntu@ubuntu-VirtualBox: ~/Downloads
GNU nano 2.2.6 File: /etc/ssh/sshd_config

# Package generated configuration file
# See the sshd_config(5) manpage for details

# What ports, IPs and protocols we listen for
Port 22
# Use these options to restrict which interfaces/protocols sshd will bind to
#ListenAddress ::
#ListenAddress 0.0.0.0
Protocol 2
# HostKeys for protocol version 2
HostKey /etc/ssh/ssh_host_rsa_key
HostKey /etc/ssh/ssh_host_dsa_key
HostKey /etc/ssh/ssh_host_ecdsa_key
HostKey /etc/ssh/ssh_host_ed25519_key
#Privilege Separation is turned on for security
UsePrivilegeSeparation yes

# Lifetime and size of ephemeral version 1 server key
KeyRegenerationInterval 3600
ServerKeyBits 1024

# Logging
SyslogFacility AUTH
LogLevel INFO

# Authentication:
LoginGraceTime 120
PermitRootLogin no
StrictModes yes

RSAAuthentication yes
PubkeyAuthentication yes
#AuthorizedKeysFile      %h/.ssh/authorized_keys

# Don't read the user's ~/.rhosts and ~/.shosts files
IgnoreRhosts yes
# For this to work you will also need host keys in /etc/ssh_known_hosts
RhostsRSAAuthentication no

^G Get Help      ^O WriteOut      ^R Read File      ^V Prev Page      ^K Cut Text      ^C Cur Pos
^X Exit          ^J Justify       ^W Where Is      ^N Next Page      ^U UnCut Text    ^T To Spell

Read 88 lines

29°C Sunny 16:50 23/06/2026
```



## Optional task

**As an optional stand out task,** you can also provide a set of best practice recommendations to the senior leadership about further securing the remote login process and password management in the organization. While you appreciate the job security, you also don't appreciate the National Peace Agency making you come in on your day off. Provide your recommendations below.

1. *Disable direct root SSH access*
2. *Disable password-based SSH authentication*
3. *Require MFA for all remote and privileged access*
4. *Use a bastion host or VPN for administrative SSH*





# Section Three: Hardening

---



Owner: admin

[illegible]



# Patching Apache

Once you have provided your report on the existing vulnerabilities on the system, you notice that the jump host is also running an Apache HTTP server which can be accessed from the internet and can serve as an attack point in future incidents. To harden the Apache server, you must remove the version banner from being publicly visible. This would make it difficult for an attacker to perform reconnaissance on the server and launch attacks. Your goal is to identify and report the current Apache server version and then the configuration change required to prevent the version number from being publicly accessible.

|                        |                                                                                                                     |
|------------------------|---------------------------------------------------------------------------------------------------------------------|
| Apache server version: | <i>[Apache HTTP Server 2.4.7 ]</i>                                                                                  |
| Required changes:      | <i>[sudo nano<br/>/etc/apache2/conf-available/security.conf<br/>ServerTokens Prod<br/>ServerSignature Off<br/>]</i> |



# De-Privilege Apache Account

As a final task of hardening the system, you want to ensure that Apache always runs as a low privileged user with restricted system access. To do that, create a new user group called “apache-group” and a new user account called “apache-user”. Provide the name of the configuration file and the exact lines that you would change to ensure that apache launches as the newly created user account.

|                     |                                                                                    |
|---------------------|------------------------------------------------------------------------------------|
| Configuration file: | <i>[sudo nano /etc/apache2/envvars ]</i>                                           |
| Lines to change:    | <i>[export APACHE_RUN_USER=www-data<br/>export APACHE_RUN_GROUP=www-data<br/>]</i> |



## Optional task

The head of security for South Udan is grateful to you for your services. They want to award you with a commendation, and you are asked to prepare an “Executive Summary” of the entire investigation and changes you have made to contain the threat. This executive summary will be used to brief the head of South Udan about the incident.

*[Write the executive summary here]*